

TỔNG HỢP CÁC LUỒNG RÒ RỈ DỮ LIỆU NỘI BỘ (TỪ 1 ĐẾN 15)

1. “database chứa dữ liệu nhạy cảm...”

→ bạn sẽ tạo một cơ sở dữ liệu (database) chứa danh sách các dữ liệu nhạy cảm.

Ví dụ trong database có thể lưu:

- Từ khóa mật (VD: mã dự án, tài khoản nội bộ, thông tin khách hàng...)
- Tên file hoặc mẫu dữ liệu (pattern)
- Nhãn dữ liệu như: Confidential, Internal, Secret...

Hệ thống DLP sẽ so sánh dữ liệu người dùng gửi ra ngoài với database này.

2. “Các nhóm mà dính dữ liệu nhạy cảm này thì kích hoạt lên”

→ Khi hệ thống phát hiện:

- Email
- File upload
- Nội dung chat
- Clipboard (copy/paste)

có trùng với dữ liệu trong database nhạy cảm, thì hệ thống sẽ:

- Kích hoạt rule bảo mật
- Có thể chặn hoặc cảnh báo.

Điều này đúng với nội dung trong tài liệu bạn gửi, ví dụ phần:

- Upload cloud cá nhân → bị block
- Copy dữ liệu vào chat/AI → bị kiểm soát

TỔNG HỢP CÁC LUỒNG RÒ RỈ DỮ LIỆU...

3. “Nhân viên được mở ChatGPT hay Zalo thoải mái...”

→ Chính sách ở đây là:

✓ Cho phép dùng bình thường

- ChatGPT
- Zalo
- Telegram
- Web

! Nhưng khi có dữ liệu nhạy cảm thì:

- Hệ thống phát hiện
- Kích hoạt cảnh báo ngay.

4. “Kích hoạt và đưa cảnh báo ngay tại máy gửi”

Điều này nghĩa là hệ thống sẽ hiện popup như kiểu:

⚠ Warning: You are sending sensitive company data.
This action is monitored or blocked.

Tức là:

- Cảnh báo trực tiếp trên máy nhân viên
- Đồng thời gửi log cho admin.

Trong tài liệu của bạn cũng có phần này:

- Popup cảnh báo người dùng
- Gửi alert cho Security team

TỔNG HỢP CÁC LƯỜNG RÒ RỈ DỮ LIỆ...

Tóm tắt cách hệ thống của bạn hoạt động

Luồng sẽ giống như thế này:

1. Nhóm bạn tạo database dữ liệu nhạy cảm
2. Nhân viên làm việc bình thường (chat, gửi file, upload cloud...)
3. Hệ thống quét nội dung
4. Nếu phát hiện dữ liệu nhạy cảm:

- Hiện cảnh báo
- Ghi log
- Có thể chặn hành động.

Ví dụ thực tế (rất giống hệ thống doanh nghiệp)

Ví dụ nhân viên copy:

Danh sách khách hàng VIP 2026.xlsx

rồi gửi vào ChatGPT hoặc Zalo.

Hệ thống sẽ:

- Detect từ khóa hoặc fingerprint file
- Hiện cảnh báo
- Log lại:
 - user
 - thời gian
 - file
 - ứng dụng đang dùng

I. NHÓM CON NGƯỜI & HÀNH VI (HUMAN FACTOR)

STT	Trường hợp	Kỹ thuật gây rò rỉ	Kỹ thuật khắc phục & Ghi Log
1	Luồng Email/File	Gửi sai người nhận; CC/BCC nhầm; Dùng email cá nhân cho công việc.	Email DLP quét nội dung; Cảnh báo trước khi gửi ra ngoài domain; Chặn gửi file qua email cá nhân.
2	Luồng Cloud	Nhân viên tải tệp tin nhạy cảm lên Google Drive cá nhân, Dropbox, WeTransfer hoặc các	1. Ghi Log (Logging): * Hệ thống Network DLP hoặc Cloud Access Security Broker (CASB) ghi lại: <i>Thời gian, Tên nhân viên,</i>

STT	Trường hợp	Kỹ thuật gây rò rỉ	Kỹ thuật khắc phục & Ghi Log
		dịch vụ lưu trữ đám mây chưa được cấp phép	<i>Tên file, Dung lượng, URL đích, Trạng thái (Thành công/Bị chặn).</i> 2. Gửi cảnh báo (Alerting): ○ Cảnh báo người dùng (User Notification): Hiện thị Popup ngay trên máy tính nhân viên thông báo hành vi upload dữ liệu nhạy cảm đang bị giám sát. ○ Cảnh báo quản trị (Admin Alert): Gửi Email hoặc tin nhắn (Telegram/Slack) tức thời cho bộ phận Security khi phát hiện file có nhãn "Confidential" được upload ra ngoài domain.
3	Chụp màn hình (Screen Capture)	Dùng phím tắt, Snipping Tool để lưu file ảnh chứa dữ liệu mật.	Chặn theo Role: Nhân viên bị chặn hoàn toàn; Quản lý được phép nhưng chèn Watermark định danh và ghi log OCR ảnh.
4	Cố ý ngụy trang (Obfuscation)	Đổi đuôi file (ví dụ: .xlsx -> .jpg); Nén file đặt mật khẩu để lách máy quét.	Content Inspection: Quét mã vạch file (Header) để biết định dạng thật; Chặn file nén có pass nếu không khai báo.
5	Chia nhỏ dữ liệu	Dùng WinRAR/7Zip cắt nhỏ file; Copy-paste từng đoạn văn bản nhỏ vào nhiều tin nhắn.	Cumulative DLP: Quét tích lũy dung lượng/từ khóa theo thời gian; Dùng Fingerprinting nhận diện mảnh ghép dữ liệu gốc.

Hành động: Đối tượng dữ liệu Phản hồi của hệ thống Ghi Log & Cảnh báo Upload lên Cloud Công ty Dữ liệu Nội bộ Cho phép (Allow) Ghi Log thông thường vào hệ thống Audit.

Upload lên Cloud Cá nhân Dữ liệu Nhạy cảm Chặn (Block) Gửi cảnh báo High Alert: Email cho Admin + Lưu bằng chứng (Evidence) của file đó.

II. NHÓM THIẾT BỊ & ENDPOINT

STT	Trường hợp	Kỹ thuật gây rò rỉ	Kỹ thuật khắc phục & Ghi Log
6	USB & Ổ cứng ngoài	Copy dữ liệu ra USB cá nhân; Làm mất thiết bị chưa mã hóa.	Endpoint DLP chặn copy ra thiết bị lạ; Chỉ cho phép USB được cấp quyền; Mã hóa bắt buộc thiết bị ngoại vi.
7	Keylogger	Cài Keylogger đánh cắp tài khoản quản trị hoặc thông tin đăng nhập nhạy cảm.	Anti-Keylogging: Chống ghi đè bàn phím; Dùng bàn phím ảo cho app mật; Giám sát hành vi cài phần mềm lạ.
8	In ấn (Printing)	In tài liệu mật ra giấy mang về; "In" ra file PDF để lách luật.	Quét nội dung lệnh in; Chèn Watermark định danh lên bản in; Chặn tính năng "Print to PDF" với file nhạy cảm.
9	Cổng ngoại vi & Âm thanh	Dùng HDMI Capture Card quay màn hình; Mã hóa dữ liệu thành tín hiệu âm thanh để ghi âm.	Peripheral Control: Chặn thiết bị lạ qua cổng HDMI/Audio; Cảnh báo khi app lạ truy cập Driver âm thanh/hình ảnh.

III. NHÓM EMAIL – CLOUD – INTERNET

STT	Trường hợp	Kỹ thuật gây rò rỉ	Kỹ thuật khắc phục & Ghi Log
10	Dịch vụ chia sẻ file	Upload lên Google Drive cá nhân, WeTransfer; Push code lên GitHub public.	Network DLP kiểm soát upload; Whitelist dịch vụ được phép; Chặn domain lạ.
11	API & Bên thứ ba	Lộ token API; Ứng dụng bên thứ ba truy cập quá quyền hạn.	Quản lý API Key tập trung; Giới hạn Scope truy cập; Audit tích hợp định kỳ.
12	Ứng dụng Chat & AI	Copy-paste dữ liệu vào Zalo, Telegram; Dùng ChatGPT/Claude để xử lý báo cáo nội bộ.	Clipboard DLP: Chặn copy từ app nội bộ dán sang app ngoài; Chặn paste dữ liệu vào các domain AI công cộng.

IV. NHÓM KỸ THUẬT NÂNG CAO & QUY TRÌNH

STT	Trường hợp	Kỹ thuật gây rò rỉ	Kỹ thuật khắc phục & Ghi Log
13	Kênh đường hầm (Tunneling)	Giấu dữ liệu vào gói tin DNS hoặc Ping (ICMP) để vượt tường lửa.	Deep Packet Inspection (DPI) : Quét sâu nội dung gói tin; Cảnh báo khi tần suất DNS/Ping tăng đột biến.

| **14 | Máy ảo & Remote Desktop** | Cài Virtual Machine để thao tác ngầm; Dùng **RDP** để copy dữ liệu sang máy tính nhà. | Chặn chạy máy ảo trên máy làm việc; Chặn tính năng "Clipboard Sharing" và "Drive Redirection" trên RDP. |

| **15 | Thùng rác & File tạm** | Giấu file mật vào Recycle Bin hoặc thư mục Temp chờ thời cơ tẩu tán. | **Deep Scan**: DLP quét cả đường dẫn ẩn và thùng rác; Quy trình tiêu hủy tài liệu giấy in lỗi bắt buộc. |